

KỊCH BẢN THỰC NGHIỆM

"Phát hiện máy, quét cổng TCP 139/445 và nhận diện dịch vụ SMB bằng Nmap"

Lưu ý: Đây là bản soạn thảo kịch bản dùng cho khóa luận. Các lệnh chỉ được thực thi sau khi có phê duyệt.

Kịch bản tuân thủ chặt các ràng buộc cấp phép: chỉ tương tác 192.168.56.0/24, tốc độ $\leq T3$, giới hạn retry, chỉ quét cổng cần thiết, **không** khai thác, **không** brute-force, **không** NSE thuộc nhóm `exploit/intrusive/brute/dos` (chỉ dùng script nhóm `safe/discovery`).

1. Mục tiêu và phạm vi

1.1. Mục tiêu

Xây dựng và thực hiện quy trình trinh sát mạng (network reconnaissance) có kiểm soát trong môi trường lab nhằm:

- Phát hiện máy hoạt động (host discovery) trong dải mạng lab.
- Xác định máy mục tiêu và kiểm tra trạng thái hai cổng SMB điển hình: **TCP 139** (NetBIOS Session Service) và **TCP 445** (SMB over TCP / Microsoft-DS).
- Nhận diện dịch vụ và phiên bản SMB, liệt kê các dialect (giao thức) SMB được hỗ trợ bằng các NSE script an toàn.
- Lưu và phân tích kết quả một cách khách quan, **không** kết luận có lỗ hổng chỉ vì cổng mở.

1.2. Phạm vi được cấp phép (In-scope)

Hạng mục	Giá trị
Dải mạng duy nhất được phép	192.168.56.0/24 (VMware Host-only)
Máy kiểm thử (attacker)	Kali Linux — 192.168.56.10
Máy mục tiêu (target)	Windows Server/Client — 192.168.56.20

1.3. Ngoài phạm vi (Out-of-scope) — TUYỆT ĐỐI KHÔNG

- Không quét Internet, mạng cơ quan/trường, hoặc bất kỳ IP nào ngoài 192.168.56.0/24.
- Không khai thác lỗ hổng (no exploitation), không brute-force tài khoản.
- Không dùng NSE nhóm *exploit*, *intrusive*, *brute*, *dos*.
- Không quét toàn bộ 65535 cổng khi không cần thiết; chỉ quét cổng liên quan mục tiêu thực nghiệm.

2. Điều kiện tiên quyết

1. **Quyền hợp pháp:** Có văn bản/biên bản cấp phép thực nghiệm trên lab 192.168.56.0/24 (đính kèm phần phụ lục khóa luận).
2. **Cách ly mạng:** VMware ở chế độ **Host-only**, không NAT/Bridge ra Internet trong lúc thực nghiệm (giảm rủi ro quét nhầm ngoài phạm vi).

3. Máy Kali:

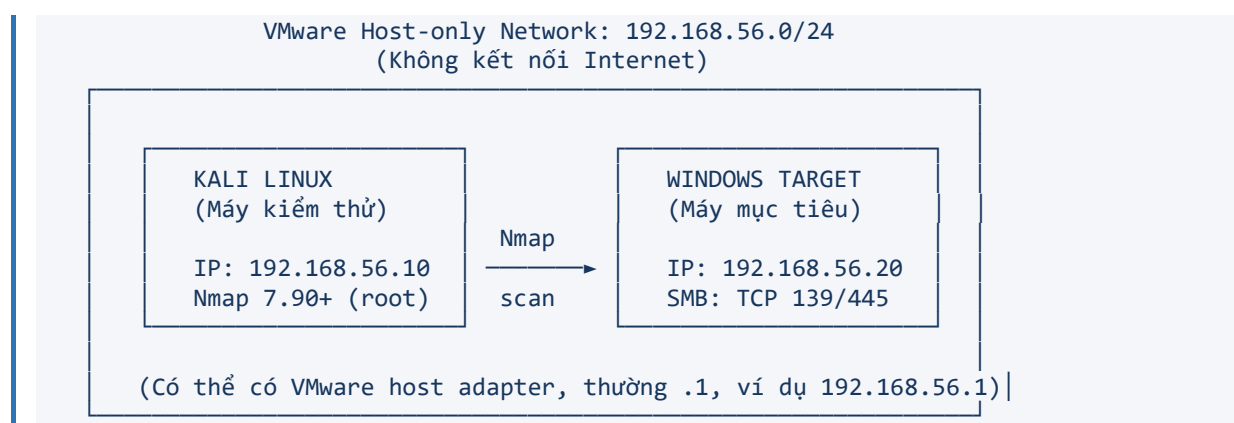
- Nmap phiên bản ≥ 7.90 (`nmap --version`).
- Quyền `root/sudo` (cần cho ARP scan `-PR` và SYN scan `-ss`).
- Card mạng gắn đúng vào host-only (`vmnet/eth`) với IP `192.168.56.10`.

4. **Máy mục tiêu:** Đang bật, kết nối cùng host-only network, IP `192.168.56.20`.

5. **Thư mục lưu kết quả** đã tạo sẵn, ví dụ `~/khoa1uan/lab-smb/`.

6. **Đồng hồ/nhật ký:** Ghi lại thời điểm bắt đầu–kết thúc mỗi bước để phục vụ báo cáo.

3. Sơ đồ địa chỉ IP



Thiết bị	IP	Vai trò	Cổng quan tâm
Kali Linux	192.168.56.10	Máy nguồn quét	—
Windows Target	192.168.56.20	Đối tượng thực nghiệm	TCP 139, TCP 445
VMware host adapter	192.168.56.1 (thường)	Gateway host-only	—

4. Danh sách công cụ

Công cụ	Mục đích trong bài
Nmap 7.90+	Host discovery, port scan, service/version detection, NSE an toàn
NSE scripts (nhóm safe/discovery)	smb-protocols, smb-os-discovery, smb2-security-mode, smb2-capabilities

Công cụ	Mục đích trong bài
ip / ifconfig	Kiểm tra cấu hình mạng Kali
ping	Kiểm tra kết nối L3 cơ bản (tùy chọn)
grep, awk, less	Phân tích file kết quả grepable/normal
xsltproc (tùy chọn)	Chuyển XML → HTML để trình bày trong khóa luận

5. Các bước thực hiện (tổng quan)

Bước	Nội dung	Mục tiêu thực nghiệm tương ứng
B1	Kiểm tra cấu hình mạng trên Kali	MT 1
B2	Phát hiện host đang hoạt động trong /24 (ARP)	MT 2
B3	Xác nhận máy mục tiêu 192.168.56.20 còn sống	MT 3
B4	Quét trạng thái TCP 139 & 445 (SYN scan)	MT 4
B5	Nhận diện dịch vụ & phiên bản SMB	MT 5
B6	Liệt kê dialect SMB bằng NSE an toàn	MT 6
B7	Lưu kết quả 3 định dạng (normal/XML/grepable)	MT 7
B8	Phân tích khách quan kết quả	MT 8

6–9. Lệnh Nmap từng bước + Ý nghĩa tham số + Kết quả mong đợi + Pass/Fail

Quy ước chung: -T3 (tốc độ Normal, không gây tải cao), --max-retries 2 (giới hạn thử lại), lưu kết quả bằng -oA (xuất đồng thời normal .nmap, XML .xml, grepable .gnmap).

BƯỚC 1 — Kiểm tra cấu hình mạng trên Kali (không dùng Nmap)

```
ip addr show
ip route show
```

Ý nghĩa:

- `ip addr show` — liệt kê interface và IP; xác nhận interface host-only đang mang IP 192.168.56.10.
- `ip route show` — kiểm tra bảng định tuyến, đảm bảo lưu lượng tới 192.168.56.0/24 đi qua đúng interface host-only.

Kết quả mong đợi: Thấy IP 192.168.56.10/24 trên interface host-only; có route trực tiếp (link) tới 192.168.56.0/24.

Pass/Fail: **Pass** nếu IP Kali đúng 192.168.56.10 và route /24 tồn tại. **Fail** nếu IP sai/không có interface host-only → dừng, sửa cấu hình VMware trước khi tiếp tục.

BƯỚC 2 — Phát hiện host đang hoạt động trong dải lab (ARP discovery)

```
sudo nmap -sn -PR 192.168.56.0/24 -T3 --max-retries 2 -oA b2_host_discovery
```

Ý nghĩa từng tham số:

Tham số	Ý nghĩa
<code>sudo</code>	ARP scan cần quyền raw socket
<code>-sn</code>	Ping scan — chỉ phát hiện host, không quét cổng
<code>-PR</code>	Dùng ARP request để phát hiện host (chính xác nhất trong LAN host-only, không phụ thuộc ICMP bị chặn)
192.168.56.0/24	Dải quét — đúng phạm vi cấp phép
<code>-T3</code>	Timing template Normal ($\leq$ yêu cầu)
<code>--max-retries 2</code>	Tối đa 2 lần gửi lại probe → giảm nhiễu/tải
<code>-oA b2_host_discovery</code>	Lưu cả 3 định dạng với tiền tố tên file

Kết quả mong đợi: Danh sách các host "Host is up", trong đó có 192.168.56.20 (và thường 192.168.56.1 là host adapter). Mỗi host kèm địa chỉ MAC (do ARP).

Pass/Fail: **Pass** nếu Nmap báo tối thiểu 1 host up và 192.168.56.20 xuất hiện. **Fail** nếu không phát hiện host nào → xử lý theo mục 12.

BƯỚC 3 — Xác nhận máy mục tiêu còn hoạt động

```
sudo nmap -sn -PR 192.168.56.20 -T3 --max-retries 2 -oA b3_target_alive
```

Ý nghĩa: Giống B2 nhưng thu hẹp về đúng 1 IP mục tiêu để xác nhận trước khi quét cổng, tránh gửi probe thừa ra toàn dải.

Kết quả mong đợi: Host 192.168.56.20 is up, có MAC address.

Pass/Fail: Pass nếu host up. Fail nếu "host down" → kiểm tra máy target/firewall (mục 12).

BƯỚC 4 — Kiểm tra trạng thái TCP 139 & 445

```
sudo nmap -sS -p 139,445 192.168.56.20 -T3 --max-retries 2 --reason -oA b4_smb_ports
```

Ý nghĩa từng tham số:

Tham số	Ý nghĩa
-sS	TCP SYN scan (half-open) — gửi SYN, đọc SYN/ACK hoặc RST, không hoàn tất bắt tay; nhanh, nhẹ
-p 139,445	Chỉ quét đúng 2 cổng cần thiết (đúng nguyên tắc tối thiểu hóa)
--reason	Hiển thị lý do Nmap kết luận trạng thái (vd syn-ack, reset) — tăng tính minh bạch cho báo cáo
còn lại	như B2

Kết quả mong đợi (một trong các khả năng):

- 139/tcp open netbios-ssn và 445/tcp open microsoft-ds (target bật SMB) — **hoặc**
- filtered (firewall chặn) — **hoặc** closed.

Pass/Fail: Pass khi Nmap trả về trạng thái rõ ràng cho cả 2 cổng (open/closed/filtered) — bản thân việc xác định được trạng thái là mục tiêu, không bắt buộc phải "open". Fail nếu không nhận được phản hồi/không kết luận được trạng thái.

BƯỚC 5 — Nhận diện dịch vụ và phiên bản SMB

```
sudo nmap -sS -sV --version-intensity 5 -p 139,445 192.168.56.20 -T3 --max-retries 2 -oA b5_smb_version
```

Ý nghĩa từng tham số:

Tham số	Ý nghĩa
-sV	Version detection — dò tên/phiên bản dịch vụ trên cổng mở

Tham số	Ý nghĩa
--version-intensity 5	Cường độ dò mức trung bình (0–9); giữ ở 5 để cân bằng độ chính xác và mức độ "ồn"
-p 139,445	Chỉ 2 cổng SMB

Kết quả mong đợi: Cột SERVICE/VERSION mô tả netbios-ssn, microsoft-ds, kèm thông tin như Windows ... microsoft-ds hoặc Samba smbd ... (nếu là Linux/Samba). Có thể suy ra hệ điều hành cấp cao.

Pass/Fail: **Pass** nếu nhận diện được service name (và version nếu có). **Fail** nếu -sV không trả thông tin dù cổng open → tăng nhẹ intensity hoặc bổ sung NSE ở B6.

BƯỚC 6 — Liệt kê giao thức/dialect SMB bằng NSE an toàn

```
sudo nmap -sS -p 139,445 \
  --script smb-protocols,smb-os-discovery,smb2-security-mode,smb2-capabilities \
  192.168.56.20 -T3 --max-retries 2 -oA b6_smb_nse
```

Ý nghĩa các script (đều thuộc nhóm safe/discovery, KHÔNG intrusive/exploit/brute/dos):

Script	Chức năng
smb-protocols	Liệt kê các dialect SMB được hỗ trợ (SMBv1, SMB2, SMB3...)
smb-os-discovery	Lấy thông tin OS, computer name, domain/workgroup qua SMB
smb2-security-mode	Cho biết signing SMB2 có được yêu cầu/bật hay không
smb2-capabilities	Liệt kê khả năng (capabilities) của các dialect SMB2

Kết quả mong đợi: Danh sách dialect (ví dụ hiển thị SMBv1 enabled/disabled, 2.0.2, 2.1, 3.x...), tên máy/OS, trạng thái signing.

Pass/Fail: **Pass** nếu ít nhất smb-protocols trả về danh sách dialect. **Fail** nếu tất cả script không trả dữ liệu (thường do 445 filtered) → ghi nhận và xử lý theo mục 12.

Ghi chú tuân thủ: 4 script trên chỉ **đọc thông tin cấu hình/định danh**. Không dùng smb-vuln-* (nhóm vuln/intrusive) vì nằm ngoài phạm vi cấp phép.

BƯỚC 7 — Lưu kết quả 3 định dạng

Việc lưu đã được thực hiện tự động ở mỗi bước qua -oA, tạo ra bộ ba file:

Định dạng	Đuôi file	Dùng để
Normal	.nmap	Đọc trực tiếp, chụp minh họa
XML	.xml	Lưu trữ có cấu trúc, chuyển HTML
Grepable	.gnmap	Trích lọc nhanh bằng grep/awk

Ví dụ trích nhanh cổng mở từ grepable và (tùy chọn) xuất HTML:

```
grep -E "139|445" b4_smb_ports.gnmap
xsltproc b6_smb_nse.xml -o b6_smb_nse.html
```

Pass/Fail: Pass nếu tồn tại đủ .nmap, .xml, .gnmap cho các bước B2–B6.

BƯỚC 8 — Phân tích kết quả (khách quan)

Tổng hợp và diễn giải, tuân thủ nguyên tắc **không suy diễn lỗ hổng**:

- Ghi nhận: cổng nào open/closed/filtered, dialect nào được hỗ trợ, signing bật hay tắt, OS/computer name.
- Chỉ mô tả hiện trạng cấu hình.** Ví dụ: "TCP 445 open, hỗ trợ SMBv1" là **quan sát cấu hình**, KHÔNG đồng nghĩa "máy có lỗ hổng". Việc có lỗ hổng cần đánh giá riêng (ngoài phạm vi bài này) qua patch level, CVE, v.v.
- Nêu khuyến nghị mang tính quan sát (vd: "nên xác minh thêm cấu hình signing/SMBv1 theo chính sách") thay vì kết luận rủi ro.

10. Bảng ghi nhận kết quả (mẫu điền khi thực hiện)

Bước	Lệnh (tóm tắt)	Thời gian	Kết quả quan sát	Pass/Fail	Ghi chú
B1	ip addr / ip route		IP Kali = ?		
B2	nmap -sn -PR /24		Số host up = ? ; có .20?		
B3	nmap -sn -PR .20		.20 up? MAC=?		
B4	nmap -sS -p139,445		139=?/445=? (reason)		
B5	nmap -sV -p139,445		Service/Version=?		

Bước	Lệnh (tóm tắt)	Thời gian	Kết quả quan sát	Pass/Fail	Ghi chú
B6	nmap --script smb-*		Dialect=? Signing=? OS=?		
B7	Kiểm tra file -oA		Đủ .nmap/.xml/.gnmap?		
B8	Phân tích		Tóm tắt hiện trạng		

11. Danh sách bằng chứng cần chụp

1. Ảnh ip addr / ip route xác nhận IP 192.168.56.10 (B1).
2. Ảnh kết quả host discovery hiển thị 192.168.56.20 is up + MAC (B2, B3).
3. Ảnh trạng thái cổng 139/445 kèm cột REASON (B4).
4. Ảnh kết quả -sV với Service/Version (B5).
5. Ảnh output NSE (dialect, OS, signing) (B6).
6. Ảnh ls -l thư mục kết quả cho thấy đủ bộ file .nmap/.xml/.gnmap (B7).
7. (Tùy chọn) Ảnh file HTML sinh từ xsltproc.
8. Ảnh đồng hồ/nhật ký ghi thời điểm bắt đầu–kết thúc (chứng minh nằm trong cửa sổ được phép).
9. Lưu bản sao các file .nmap/.xml làm phụ lục khóa luận.

12. Các tình huống lỗi và cách xử lý

Tình huống	Nguyên nhân thường gặp	Cách xử lý (trong phạm vi)
B2 không phát hiện host nào	Sai interface/IP Kali; VMware chưa gắn host-only	Kiểm tra lại ip addr; gắn đúng vmnet host-only; đảm bảo Kali .10
.20 báo "host down"	Máy target tắt; firewall chặn ARP/ICMP	Bật lại target; vì -PR dùng ARP nên hầu như luôn thấy nếu cùng L2; kiểm tra target cùng subnet
139/445 hiển thị filtered	Windows Firewall chặn	Ghi nhận là "filtered" (kết quả hợp lệ); KHÔNG cố vượt firewall bằng evasion (ngoài phạm vi)

Tình huống	Nguyên nhân thường gặp	Cách xử lý (trong phạm vi)
-sV không ra version	Dịch vụ ẩn banner	Dùng NSE B6 để bổ sung thông tin; không nâng intensity quá cao
NSE báo ERROR: Script execution failed	445 filtered/không truy cập được	Xác nhận lại B4; nếu filtered thì ghi nhận, không ép chạy
"You requested a scan type which requires root"	Thiếu quyền cho -sS/-PR	Chạy với sudo
Quét chậm bất thường	Nhiều retry do mất gói	Giữ --max-retries 2; kiểm tra tải VMware; không tăng -T vượt T3
Lỗi nhập IP ngoài phạm vi	Gõ nhầm dải	Dừng ngay (Ctrl+C); chỉ dùng 192.168.56.0/24; ghi nhận sự cố vào nhật ký

13. Phần kết luận thực nghiệm (khung mẫu để hoàn thiện sau khi chạy)

Sau khi thực hiện, phần kết luận nên nêu:

- Xác nhận quy trình:** Đã phát hiện host, xác định 192.168.56.20, kiểm tra được trạng thái TCP 139/445, nhận diện dịch vụ/phần bản và liệt kê dialect SMB bằng NSE an toàn — toàn bộ trong phạm vi cấp phép, $\leq T3$, retry giới hạn, chỉ cố gắng cần thiết.
- Tóm tắt hiện trạng quan sát được** (điền từ Bảng mục 10): cổng open/filtered, dialect hỗ trợ, signing, OS.
- Giới hạn của thực nghiệm:** Chỉ là trinh sát/định danh; **không** đánh giá lỗ hổng, **không** khai thác. Cổng SMB mở **không** đồng nghĩa có lỗ hổng.
- Hướng phát triển (khuyến nghị, ngoài phạm vi bài này):** đánh giá cấu hình signing/SMBv1 theo chính sách bảo mật, kiểm tra patch level — thực hiện trong một thực nghiệm riêng có cấp phép tương ứng.
- Giá trị học thuật:** Minh họa quy trình reconnaissance chuẩn, có kiểm soát, có đạo đức và tuân thủ phạm vi — phù hợp làm cơ sở phương pháp trong khóa luận.